🧰 도구(플러그인) 올리기 안내

Guardian 대시보드 > 도구 메뉴 > "도구 올리기" 에서 쓰는 방법입니다. 이 문서는 도구 올리기용이고, 탐지 규칙(플러그인 방식)은 "탐지 규칙 올리기 안내" PDF를 보세요.

1. 한눈에 보기

도구는 대시보드에서 버튼으로 실행하고 결과를 화면에서 보는 작은 프로그램입니다 (핑 확인, 시스템 상태 보기 등). 도구 하나는 **설정 파일 1개(`plugin.json`) + 스크립트 1개 이상**입니다.

① 파일 만들기
내 PC에서 `plugin.json` 과 스크립트(`.py` / `.sh`)를 만듭니다.

② 올리기
대시보드 "도구 올리기"에서 파일을 모두 선택해 올립니다.

③ (선택) 시험
"🧪 샌드박스로 실행"으로 설치 없이 격리된 곳에서 한 번 돌려 봅니다.

④ 승인
관리자가 서버 터미널에서 코드를 읽고 승인하면 카드로 나타납니다.

> **왜 바로 안 쓰이나요?** 올린 스크립트는 서버에서 실행되는 코드입니다. 대시보드 토큰이 새도 올리기만으로는 아무것도 실행되지 않도록, 승인은 **서버 터미널에서만** 할 수 있게 해 두었습니다. 대시보드에는 승인 버튼이 없습니다.

2. 올릴 파일

파일	설명
`plugin.json` (필수)	이름·설명·태그·실행 방법·입력값을 적는 설정 파일. 이름은 반드시 `plugin.json`.
`run.py` / `run.sh` 등	실제로 일하는 스크립트. `.py` 또는 `.sh` 만 가능. 화면에 보일 내용은 그냥 `print()` (또는 `echo`) 하면 됩니다.

- 한 번에 **6개**까지, 파일당 **64KB** 까지.
- 파일 이름은 영문·숫자·`.` `_` `-` 만 쓰고, 확장자는 `.json` `.py` `.sh` 만 가능합니다.
- 같은 `id` 를 다시 올리면 승인 대기 중인 이전 것을 덮어씁니다. 이미 설치된 `id` 는 올릴 수 없습니다.

3. plugin.json 항목

```
{
  "id": "ping_check",
  "name": "핑 확인",
  "description": "지정한 IP 로 ping 3번을 보내 연결 상태를 확인합니다.",
  "tags": ["핑", "연결확인"],
  "kind": "task",
  "command": ["ping", "-c", "3", "-W", "2", "{host}"],
  "params": [
    {"name": "host", "label": "대상 IP", "type": "ip", "default": "192.168.56.20"}
  ],
  "timeout_sec": 15
}
```

항목	필수	설명
`id`	필수	영소문자로 시작, 영소문자·숫자·밑줄만, 40자까지. 올린 폴더 이름이 되고 다른 도구와 겹치면 안 됩니다.
`name`	권장	카드에 보일 이름 (60자까지).
`description`	권장	카드에 보일 설명 (300자까지).
`tags`	선택	카드 이름 밑에 **#포트공격** 처럼 보일 태그. 6개까지, 공백 없이 20자까지. 태그를 누르면 그 태그의 도구만 모아 볼 수 있습니다.
`kind`	선택	`task` = 한 번 실행하고 끝 (기본값) / `service` = 중지할 때까지 계속 실행 (카드에 켜기/끄기 스위치가 생김).
`command`	필수	실행할 명령을 **목록**으로 씁니다 (1~20개). 셸을 거치지 않습니다. `{python}` = 서버의 파이썬, `"./run.py"` = 올린 파일, `{이름}` = 입력값. 첫 항목에 경로(`/bin/...`)는 쓸 수 없고, `..` 도 안 됩니다. `./` 로 쓴 파일은 같이 올려야 합니다.
`params`	선택	실행할 때 사용자에게 받을 입력값 (8개까지). 아래 표 참고.
`timeout_sec`	선택	한 번 실행의 시간 제한 (1~600초, 기본 30). `task` 에만 적용.

입력값(params) 한 칸의 모양

항목	설명
`name`	영소문자로 시작, 영소문자·숫자·밑줄 20자까지. `command` 에서 `{name}` 으로 부릅니다.
`label`	화면에 보일 이름 (60자까지).
`type`	`ip` (IP 주소) / `int` (정수, `min`·`max` 가능) / `choice` (`choices` 에 2~20개) / `text` (영문·숫자·일부 기호만, `-` 로 시작 불가).
`default`	기본값. 사용자가 비워 두면 이 값을 씁니다.

> 입력값은 서버가 먼저 검사한 뒤 명령의 **인자로만** 들어갑니다. 그래서 사용자가 이상한 문장을 넣어도 명령이 끼어들 수 없습니다.

4. 스크립트 쓰는 법

화면에 보여 줄 내용을 그냥 출력하면 됩니다 (최근 500줄이 카드의 ⚙ 창에 보입니다). 입력값은 `command` 에 적은 순서대로 인자로 들어옵니다.

```
#!/usr/bin/env python3
# run.py - command 가 ["{python}", "-u", "./run.py", "{host}"] 일 때
import sys
host = sys.argv[1]
print("대상:", host)
print("여기에 하고 싶은 일을 씁니다")
```

- `kind` 가 `service` 면 파이썬은 `-u` 옵션(`"{python}", "-u", "./run.py"`)을 쓰세요. 안 쓰면 출력이 늦게 보입니다.
- 종료 코드가 0 이 아니면 카드에 "실패"로 표시됩니다.
- 도구는 대시보드 서버와 같은 일반 계정(`kali`) 권한으로 실행됩니다. root 권한이 필요한 일은 할 수 없습니다.

결과를 표·그래프로 보여 주기 (선택)

`@gui ` 로 시작하고 뒤에 JSON 이 붙은 줄을 출력하면, 화면이 그 줄을 글자 대신 숫자 카드·표·막대·그래프로 그립니다. 나머지 줄은 "원본 출력"에 그대로 남습니다.

```
import json
def gui(**b): print("@gui " + json.dumps(b, ensure_ascii=False), flush=True)

gui(type="metric", label="메모리 사용", value=63.5, unit="%", max=100)   # 숫자 카드 (max 가
있으면 막대)
gui(type="table", title="열린 포트", columns=["포트", "서비스"], rows=[[22, "ssh"], [8080, "대
시보드"]])
gui(type="bars", title="IP별 연결 수", items=[["192.168.56.20", 12], ["192.168.57.1", 3]])
gui(type="chart", label="부하(1분)", value=0.42, max=2)   # 같은 label 로 계속 출력하면 그래프가
쌓임 (최근 60개)
gui(type="alert", level="warning", text="디스크가 90% 를 넘었습니다")   # info / success /
warning / error
```

- 같은 이름(label 또는 title)으로 다시 출력하면 새 값으로 바뀝니다 (chart 만 쌓임).
- 표는 200줄·12칸, 막대는 50개, 글자는 칸마다 200자까지만 보입니다. JSON 이 틀린 줄은 그냥 글자로 보입니다.
- 예제: `system_info` (카드·막대·표), `heartbeat` (그래프).

5. 올리기 · 시험 · 승인

(1) 올리기

대시보드 > 도구 > "도구 올리기" 에서 `plugin.json` 과 스크립트를 **한꺼번에** 선택하고 "⬆ 올리기". 설정이 틀리면 이유가 바로 표시됩니다. 통과하면 "승인 대기 중" 목록에 나타납니다 (아직 실행되지 않습니다).

(2) 샌드박스로 시험 (선택)

승인 대기 항목의 "🧪 **샌드박스로 실행**"은 설치하지 않고 한 번만 돌려 봅니다. 네트워크가 없고, 파일은 읽기 전용이고, 메모리·프로세스 수·시간이 제한된 격리 상태입니다. 결과는 저장되지 않습니다. (격리 상태라서 핑처럼 네트워크가 필요한 도구는 시험에서 실패할 수 있습니다.)

(3) 승인 (서버 터미널에서만)

```
cd ~/guardian
python3 dashboard/approve_plugin.py list              # 승인 대기 목록
python3 dashboard/approve_plugin.py show ping_check    # 파일 내용과 주의할 패턴 보기
python3 dashboard/approve_plugin.py approve ping_check # 내용을 다시 보여 주고 해시를 입력하면 승인
python3 dashboard/approve_plugin.py reject ping_check  # 거절(삭제)
```

승인하면 `plugins/` 로 옮겨지고 3초 안에 도구 카드로 나타납니다. 승인하는 사람은 **코드를 직접 읽어야** 합니다.

> **주의 표시는 보안 장치가 아닙니다.** `sudo`, `curl`, `subprocess` 같은 패턴이 있으면 "주의" 로 표시해 줄 뿐이고, 표시가 없다고 안전한 것은 아닙니다. 모르는 사람이 올린 코드는 승인하지 마세요.

6. 자주 나는 오류

메시지(요약)	고치는 법
plugin.json 이 필요합니다 / plugin.json (도구) 이 필요한 칸	파일 이름이 정확히 `plugin.json` 인지, 도구 칸에 올렸는지 확인 (탐지 규칙은 다른 칸).
id 는 영소문자로 시작하고…	`id` 를 영소문자로 시작하고 영소문자·숫자·밑줄만 쓰세요.
command 의 ./파일 이 함께 올라오지 않았습니다	`command` 에 쓴 `./run.py` 를 같이 선택해서 올리세요.
command 의 첫 항목에는 경로를 쓸 수 없습니다	`/bin/ping` 대신 `ping`, 올린 파일은 `./이름` 으로.
tags 는 6개 이하의 짧은 단어…	태그는 6개까지, 공백 없이 20자까지.
이미 설치된 플러그인 id 입니다	다른 `id` 를 쓰세요.
승인 대기 목록이 가득 찼습니다	안 쓰는 대기 항목을 삭제하세요 (최대 20개).

7. 올리기 전 점검표

- ☐ `plugin.json` 의 `id` 가 영소문자로 시작하고 다른 도구와 겹치지 않는다.
- ☐ `command` 의 `./파일` 을 모두 같이 올렸다 (6개·64KB 이내).
- ☐ 입력값에 `default` 를 넣었다 (서비스형 카드의 스위치는 기본값으로 시작합니다).
- ☐ 스크립트가 root 권한이나 외부 인터넷을 꼭 필요로 하지 않는다.
- ☐ `tags` 로 무슨 도구인지 알 수 있게 달았다 (예: `#포트공격`).